

מבחן מעשי

חומר לימוד

1 יחידות

תוכן העניינים

1.  מבחן מעשי (Practical Exam)

מבחן מעשי (Practical Exam) 🏆

מבחן בסגנון ההסמכות המקצועיות (PNPT / OSCP): בדיקת חדירות מלאה מקצה לקצה + כתיבת דוח. זו הדרך האמיתית להוכיח שליטה — לא שינון, אלא ביצוע.

⚠️ המבחן מתבצע אך ורק על מכונות תרגול חוקיות (VulnHub / TryHackMe / HackTheBox) במעבדה שלך.

התרחיש (Scenario) 📋

חברת "Acme Corp" שכרה אותך לבצע בדיקת חדירות. אתה מקבל גישה לרשת המעבדה שבה מספר מכונות. **המשימה:** לחדור לכמה שיותר מכונות, להשיג את ההרשאות הגבוהות ביותר (root / SYSTEM), ולכתוב דוח מקצועי.

מטרת-על: להוכיח שאתה שולט בשרשרת התקיפה המלאה שנלמדה במודולים 1–7 (ובהמשך 8–16).

יעדים (Objectives) 🎯

עבור כל מכונה שתתקוף: 1. גילוי ומנייה — מצא את המכונה, מפה את כל הפורטים והשירותים. 2. זיהוי חולשה — מצא לפחות וקטור תקיפה אחד. 3. ניצול והשגת גישה — השג Shell. 4. הסלמת הרשאות — הגע ל-root/SYSTEM (מלא במיוחד לאחר מודול 11). 5. הוכחה (Proof) — לכד את דגלי ההוכחה: local.txt (משתמש) ו-root.txt / proof.txt (root), או צילום whoami.

פורמט וזמנים 🕒

- **שלב הבדיקה:** 48 שעות (כמו PNPT) — או קצב עצמי אם אתה לומד.
- **שלב הדוח:** 24 שעות נוספות לכתיבת דוח מקצועי.
- **ללא כלים אוטומטיים מלאים:** מותר nmap/Metasploit/Nessus, אך ההבנה היא הנבחנת — תעד ידנית כל צעד.

סביבת המבחן — מכונות מומלצות (לפי קושי) 🖥️

בחר מסלול לפי רמתך. הורד מ-VulnHub והרץ במעבדה מבודדת, או השתמש ב-TryHackMe/HackTheBox.

רמה	מכונה מומלצת	מה מתרגלים
מתחיל 🟢	Kioptrix Level 1	nmap, Samba/mod_ssl exploit → root
מתחיל 🟢	Metasploitable 2	ריבוי שירותים פגיעים, Metasploit
בינוני 🟡	Kioptrix Level 2–3	Web → RCE → privesc
בינוני 🟡	TryHackMe: Blue	EternalBlue (MS17-010)
מתקדם 🟠	HackTheBox: Lame / Legacy	ניצול קלאסי מקצה לקצה
אתגר 🔴	TryHackMe: Kenobi / Vulnnet	שרשרת מלאה + privesc

טבלת ניקוד (Scoring Rubric) — 100 נקודות 📊

רכיב	נקודות	קריטריון
מנייה מלאה	20	כל הפורטים/השירותים/הגרסאות מתועדים
זיהוי חולשה	15	וקטור תקיפה מזוהה ומנומק (CVE/searchsploit)
גישה ראשונית	25	Shell הושג (Low-priv) עם הוכחה
הסלמת הרשאות	20	root/SYSTEM הושג עם הוכחה
דוח מקצועי	20	Executive Summary + ממצאים + PoC + תיקונים
סך מעבר	70	

בהסמכות אמיתיות (PNPT/OSCP) דוח שלא נכתב = כישלון, גם אם פרצת הכל. הדוח הוא התוצר. 💡

דרישות הדוח (Report Requirements) 📄

הדוח (ראה מבנה מלא במודול 16) חייב לכלול:

- 1. Executive Summary — תקציר למנהלים (לא טכני): מה נמצא, מה הסיכון.
- 2. מתודולוגיה — כיצד ניגשת (5 השלבים).
- 3. ממצאים (Findings) — לכל ממצא:

◦ כותרת + חומרה (CVSS: Critical/High/Medium/Low)

◦ תיאור החולשה

◦ **Proof of Concept** — צעדים + צילומי מסך לשחזור

◦ **המלצת תיקון (Remediation)**

4. **נספח טכני** — פלטי כלים, פקודות.

✓ צ'ק-ליסט לפני הגשה

- ☐ מיפיתי את כל המכונות ואת כל השירותים
- ☐ לכל מכונה — זיהיתי וקטור תקיפה מנומק
- ☐ השגתי Shell (Low-priv) לפחות במכונה אחת
- ☐ הסלמתי ל-root/SYSTEM לפחות במכונה אחת
- ☐ לכדתי את דגלי ההוכחה / צילומי `whoami`
- ☐ כתבתי דוח מלא עם Executive Summary, ממצאים, PoC ותיקונים
- ☐ כל ממצא כולל צילומי מסך לשחזור

🎓 אחרי המבחן

עברת בהצלחה? אתה מוכן להתמודד עם: - **eJPT (INE)** — ההסמכה המתאימה ביותר לסיום הקורס. - ואז **PNPT / OSCP** להתקדמות.

📚 קודם תרגל עם הדוגמאות מהעולם האמיתי ובנק השאלות, ואז גש למבחן.

⬅ חזרה למפת הקורס